

SQL Injection 101

A short writeup about classic SQL injection.

Reconnaissance

First we send a login request:

```
import requests
resp = requests.post('https://vuln.example.com/login')
print(resp.status_code)
```

Exploitation

We use a tautology payload to bypass auth.

Shell output

```
$ curl -X POST https://vuln.example.com/login  
[+] session cookie obtained
```

Lessons learned:

- Use parameterized queries
- Never trust client input
- Log authentication failures